OWASP COMPLIANCE

AUDIT REPORT

GenAI Top 10 + OWASP Top 10 Security Assessment

TARGET APPLICATION

https://github.com/AdityaGupta32/Smart-construction-safety-Helmet

RISK SCORE	FINDINGS	OWASP T10	GENAI T10
2.5/10	215	8/10	5/10

Generated: 2026-10-23 19:01 UTC

CONFIDENTIAL - For authorized personnel only

1. Executive Summary

This OWASP compliance audit was conducted against https://github.com/AdityaGupta32/Smart-construction-safety-H. The assessment identified 215 security finding(s) (7 Critical, 3 High, 2 Medium, 172 Low, 31 Informational). The overall risk score is 2.5/10. OWASP Top 10 compliance: 2 categories failed. OWASP GenAI Top 10 compliance: 1 categories failed.

2. OWASP Top 10 (2021) Compliance

ID	CATEGORY	STATUS	FINDINGS	RISK LEVEL
A01:2021	Broken Access Control	PASS	55	MEDIUM
A02:2021	Cryptographic Failures	PASS	0	LOW
A03:2021	Injection	FAIL	11	HIGH
A04:2021	Insecure Design	PASS	0	LOW
A05:2021	Security Misconfiguration	FAIL	204	HIGH
A06:2021	Vulnerable and Outdated Components	PASS	27	MEDIUM
A07:2021	Identification and Authentication F	PASS	0	LOW
A08:2021	Software and Data Integrity Failure	PASS	0	LOW
A09:2021	Security Logging and Monitoring Fai	PASS	0	LOW
A10:2021	Server-Side Request Forgery (SSRF)	PASS	0	LOW

3. OWASP GenAI Top 10 (2025) Compliance

ID	CATEGORY	STATUS	FINDINGS	INHERENT	MITIGATIONS
LLM01	Prompt Injection	FAIL	9	CRITICAL	4 controls
LLM02	Insecure Output Handling	PARTIAL	2	HIGH	3 controls
LLM03	Training Data Poisoning	PARTIAL	26	HIGH	3 controls
LLM04	Model Denial of Service	PASS	0	MEDIUM	4 controls
LLM05	Supply Chain Vulnerabilities	PASS	0	MEDIUM	3 controls
LLM06	Sensitive Information Disclosu	PASS	51	HIGH	3 controls
LLM07	Insecure Plugin Design	PARTIAL	26	HIGH	3 controls
LLM08	Excessive Agency	PASS	0	MEDIUM	3 controls
LLM09	Overreliance	PARTIAL	2	MEDIUM	3 controls
LLM10	Model Theft	PASS	0	MEDIUM	3 controls

OWASP

4. Findings by OWASP Category

A01:2021 - Broken Access Control

Status: PASS | 55 finding(s)

- **[Info] Open Port**
  github.com:80
- **[Info] Open Port**
  github.com:443
- **[Info] Open Port**
  github.com:22
- **[Info] Open Port**
  github.com:53
- **[Info] Tech Stack Disclosure**
  https://github.com/features/code-review

A03:2021 - Injection

Status: FAIL | 11 finding(s)

- **[Critical] Remote Code Execution**
  https://github.com/login?return_to=https%3A%2F%2Fgithub.com%2FAdityaGupta32%2FSm...
- **[Critical] Server-Side Template Injection**
  https://github.com/login?return_to=https%3A%2F%2Fgithub.com%2FAdityaGupta32%2FSm...
- **[High] Client-Side Template Injection**
  https://github.com/login?return_to=https%3A%2F%2Fgithub.com%2FAdityaGupta32%2FSm...
- **[Medium] Reflected XSS**
  https://github.com/login?return_to=https%3A%2F%2Fgithub.com%2FAdityaGupta32%2FSm...
- **[Critical] Remote Code Execution**
  https://github.com/resources/articles?topic=ai

A05:2021 - Security Misconfiguration

Status: FAIL | 204 finding(s)

- **[Info] Open Port**
  github.com:80
- **[Info] Open Port**
  github.com:443
- **[Info] Open Port**
  github.com:22
- **[Info] Open Port**
  github.com:53
- **[Info] Tech Stack Disclosure**
  https://github.com/features/code-review

A06:2021 - Vulnerable and Outdated Components

Status: PASS | 27 finding(s)

- **[Info] Tech Stack Disclosure**
  https://github.com/features/code-review
- **[Info] Tech Stack Disclosure**
  https://github.com/solutions/executive-insights

OWASP AUDIT

- **[Info] Tech Stack Disclosure**
  https://github.com/solutions
- **[Info] Tech Stack Disclosure**
  https://github.com/partners
- **[Info] Tech Stack Disclosure**
  https://github.com/why-github

OWASP AUDIT

5. GenAI Threat Analysis & Mitigations

LLM01: Prompt Injection [FAIL]

Manipulating LLMs through crafted inputs to cause unintended actions, bypassing safety measures or generating harmful content.

Recommended Controls:

* Input sanitization and validation before LLM processing
* Privilege separation between LLM and system actions
* Human-in-the-loop for sensitive operations

LLM02: Insecure Output Handling [PART

Insufficient validation of LLM outputs leading to downstream security issues including XSS, CSRF, SSRF, or code execution.

Recommended Controls:

* Treat LLM output as untrusted user input
* Apply output encoding and sanitization
* Validate LLM responses before rendering

LLM03: Training Data Poisoning [PART

Manipulation of training data to introduce vulnerabilities, backdoors, or biases into the model.

Recommended Controls:

* Validate and curate training data sources
* Implement data integrity verification
* Regular model auditing and testing

LLM04: Model Denial of Service [PASS

Attackers cause resource-heavy operations on LLMs, leading to service degradation or high costs.

Recommended Controls:

* Rate limiting on LLM API endpoints
* Input length restrictions
* Resource monitoring and auto-scaling limits

LLM05: Supply Chain Vulnerabilities [PASS

Dependency on vulnerable third-party components, models, or data sources.

Recommended Controls:

* Vet third-party model providers
* Use model signing and verification
* Regular dependency auditing

LLM06: Sensitive Information Disclosure

[PASS

LLMs may inadvertently reveal sensitive information through their responses.

Recommended Controls:

* Data sanitization in training and fine-tuning
* PII detection and redaction in outputs
* Access controls on sensitive data

LLM07: Insecure Plugin Design

[PART

LLM plugins may have insecure input handling, insufficient access controls.

Recommended Controls:

* Parameterized plugin inputs
* Strict access control on plugin actions
* Input validation and sanitization

LLM08: Excessive Agency

[PASS

LLM-based systems may take actions that lead to unintended consequences due to excessive permissions.

Recommended Controls:

* Principle of least privilege for LLM actions
* Human approval for high-impact operations
* Action logging and audit trails

LLM09: Overreliance

[PART

Blindly trusting LLM outputs without verification can lead to security vulnerabilities.

Recommended Controls:

* Human review of LLM-generated security decisions
* Cross-validation with multiple sources
* Confidence scoring and uncertainty flags

LLM10: Model Theft

[PASS

Unauthorized access to or extraction of proprietary LLM models.

Recommended Controls:

* Network segmentation for model endpoints
* API authentication and rate limiting
* Model watermarking

6. Compliance Scorecard

Overall Compliance Score

Framework Breakdown

OWASP Top 10	PASS: 8	PARTIAL: 0	FAIL: 2	80%
OWASP GenAI Top 10	PASS: 5	PARTIAL: 4	FAIL: 1	70%

7. Remediation Roadmap

Phase 1 - Immediate (0-7 days)

Critical and High severity findings | 10 item(s)

> Remote Code Execution: Never use shell=True with user input.
> Server-Side Template Injection: Pass input as data not template string.
> Client-Side Template Injection: Use v-pre or ng-non-bindable.
> Remote Code Execution: Never use shell=True with user input.
> Server-Side Template Injection: Pass input as data not template string.

Phase 2 - Short-term (7-30 days)

Medium severity findings and failed OWASP categories | 2 item(s)

> Reflected XSS: Context-aware output encoding.
> Reflected XSS: Context-aware output encoding.

Phase 3 - Long-term (30-90 days)

Low severity, informational items, and hardening | 203 item(s)

> Open Port: Close port or restrict with firewall.
> Open Port: Close port or restrict with firewall.
> Open Port: Close port or restrict with firewall.
> Open Port: Close port or restrict with firewall.
> Tech Stack Disclosure: Disable server signature tokens.

This report was generated by VerseScan's OWASP GenAI Audit Engine. Findings are mapped automatically using CWE and keyword analysis. For AI-enhanced analysis, connect the LLM Gateway service.

OWASP AUDIT